Experiment No. 15

Detect SQL Injection Vulnerabilities Using Various SQL Injection Detection Tools

AIM

To detect SQL Injection vulnerabilities in a target web application using multiple automated SQL injection detection tools such as OWASP ZAP, sqlmap, and Burp Suite Scanner, and to compare their findings.

PROCEDURE

1. Run OWASP ZAP's Active Scan (SQL Injection rules enabled) against the target application and record all parameters flagged as vulnerable.
2. Run sqlmap in detection-only mode against the same parameters: sqlmap -u "" --batch --level=3 --risk=2 to test multiple injection techniques (boolean, error-based, time-based, UNION-based).
3. Use Burp Suite's Intruder with an SQL injection payload list on each identified parameter and analyze response length/time/error differences.
4. Compare the detection results from all three tools for each parameter to identify consensus findings and reduce false positives.
5. For parameters flagged by sqlmap, note the specific injection technique(s) that succeeded (e.g., time-based blind, boolean-based blind).
6. Record response time anomalies (for time-based) and error message disclosures (for error-based) observed during testing.
7. Summarize all confirmed SQL injection points along with the detection technique and tool(s) that identified them.

SAMPLE OUTPUT

```
sqlmap detection summary for /search.php?query=test:
  Parameter: query (GET)
  Type: boolean-based blind     Payload: query=test' AND 1=1-- -
  Type: time-based blind        Payload: query=test' AND SLEEP(5)-- -
  Type: UNION query             Payload: query=test' UNION SELECT NULL,NULL-- -
  the back-end DBMS is MySQL >= 5.0.12

OWASP ZAP Alert: [High] SQL Injection - /search.php (param: query)
Burp Intruder: response time for payload 'SLEEP(5)' = 5.21s vs baseline 0.08s

Consensus: 3/3 tools confirm SQL Injection on /search.php parameter 'query'.
```

RESULT

SQL injection vulnerabilities in the target web application were successfully detected and cross-verified using OWASP ZAP, sqlmap, and Burp Suite Intruder, with all three tools confirming a high-confidence SQL injection point in the search functionality.